

API Security Risk Analysis Report

SaaS Architecture Vulnerability Assessment

Target API: JSONPlaceholder (Test
Environment)

Prepared by: VENKATA BHARGAV
CH S

Role: Cyber Security Intern

Date: June 2026

Finding 1: Unauthenticated Endpoint Access

Risk Level: HIGH

What is the issue?

The /users API endpoint allows direct GET requests without requiring an API Key, JWT (JSON Web Token), or OAuth authentication.

Why does it matter?

Anyone on the internet can access this endpoint. In a real-world SaaS application, this would allow unauthorized threat actors to access the backend database without needing to log in.

Remediation Steps

Implement strict Access Controls.

Require all API requests to include a valid Bearer Token in the authorization header.

Finding 2: Excessive Data Exposure

Risk Level: MEDIUM

What is the issue?

When querying the user list, the API returns the entire database object for each user, including sensitive PII (Personally Identifiable Information) such as exact GPS coordinates (lat, lng), phone numbers, and company details.

Why does it matter?

Attackers can easily scrape this endpoint to harvest user data for identity theft or phishing attacks. An app usually only needs the

username and email to display a list, not their entire profile.

Remediation Steps

Implement Data Transfer Objects (DTOs) on the backend to filter the data. Only send the specific data fields required by the frontend application.

Finding 3: Missing Rate Limiting

Risk Level: MEDIUM

What is the issue?

Analysis of the HTTP response headers shows no indication of API rate limiting (e.g., no X-RateLimit-Limit headers). The endpoint accepts unlimited rapid requests.

Why does it matter?

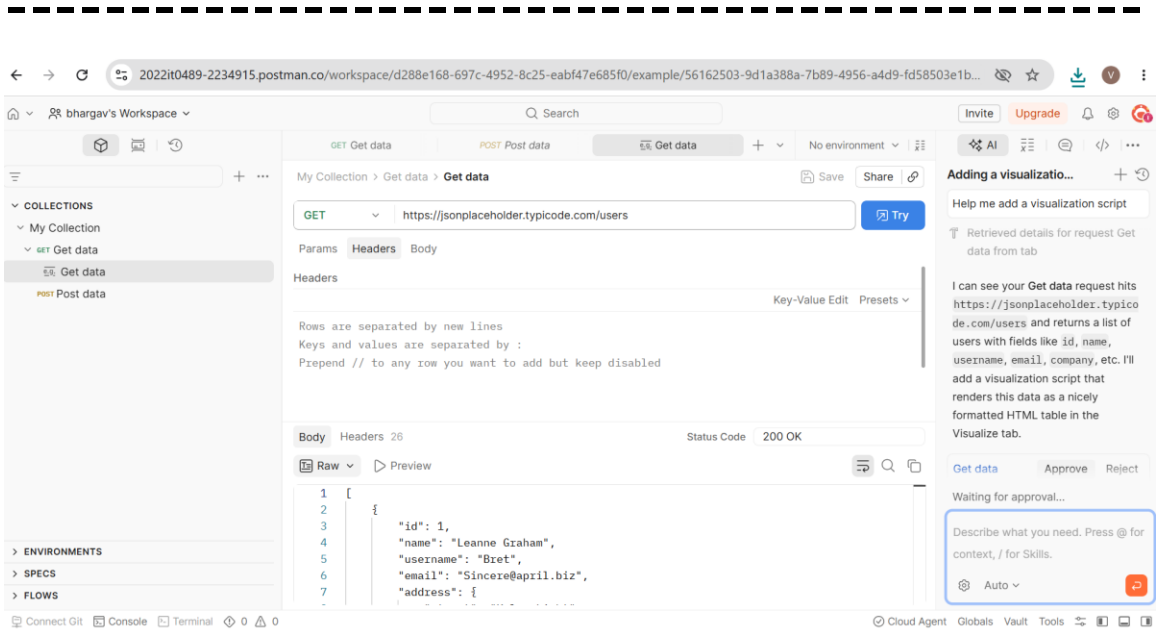
Without rate limiting, the API is vulnerable to Denial of Service (DoS) attacks, where an attacker spams the server with millions of requests to crash the system. It also allows automated bots to scrape the entire database in seconds.

Remediation Steps

Configure the API Gateway to throttle requests (e.g., limit users to 100 requests per minute per IP address).

Appendix: Technical Evidence

Instructions for Intern: Paste your Postman screenshots below.



2022it0489-2234915.postman.co/workspace/d288e168-697c-4952-8c25-eabf47e685f0/example/56162503-9d1a388a-7b89-4956-a4d9-fd58503e1bee?sid...

bhargav's Workspace

Search

Invite Upgrade

COLLECTIONS

My Collection

GET Get data

POST Post data

GET Get data

POST Post data

My Collection > Get data > Get data

Save Share

GET https://jsonplaceholder.typicode.com/users Try

Params Headers Body

Query Params

Key	Value	Description	Bulk Edit	...
Key	Value	Description		

Body Headers 26

Status Code 200 OK

Key	Value
Date	Thu, 25 Jun 2026 05:55:36 GMT
Content-Type	application/json; charset=utf-8
Content-Length	1847
Connection	keep-alive
Access-Control-Allow-Credentials	true
Cache-Control	max-age=43200

Adding a visualization...

Help me add a visualization script

```
var users = pm.response.json();
return {
  id: user.id,
  name: user.name,
  username: user.username,
  email: user.email,
  phone: user.phone,
  website: user.website,
  company: user.company
};
pm.visualizer.set(users, {});
```

Waiting for approval...

Describe what you need. Press @ for context, / for Skills.

Auto

Connect Git Console Terminal

Cloud Agent Globals Vault Tools